Plan de Seguridad

Aplicado al Desarrollo de un Nuevo Sistema de Software (FintechCorp)

Contexto y Proyecto

Estableciendo bases de seguridad para el desarrollo seguro de nuestra plataforma de servicios financieros digitales.

1. Sentar Bases y Reglas del Proyecto

Definición de Alcance

Establecer qué se va a hacer y cómo se va a hacer. Se fija el rumbo del proyecto desde el primer día de ingeniería.

Acuerdos Obligatorios

Definir las reglas principales que todo el equipo debe respetar: cero contraseñas en código duro, uso obligatorio de HTTPS y validación estricta de entradas.

2. Establecer Equipos y Responsabilidades

Equipo de Desarrollo

Encargados de escribir código seguro y aplicar revisiones de pares (Code Review) enfocadas en OWASP Top 10.

Equipo Azul (Defensa)

Responsables de monitorear vulnerabilidades, configurar firewalls de aplicaciones web y validar la infraestructura.

Líder de Seguridad

Coordina la respuesta a incidentes, reportes al cliente y priorización de fallas críticas.

3. Postura Base de Seguridad

Definir el mínimo obligatorio de protección que debe tener la aplicación antes de escalar:

- **Autenticación robusta:** Contraseñas seguras cifradas con Argon2/Bcrypt y soporte para MFA obligatorio.
- **Control de Accesos:** Principio de menor privilegio en bases de datos y APIs.
- **Cifrado de Datos:** Información sensible cifrada tanto en tránsito (TLS 1.3) como en reposo (AES-256).



Seguridad por Defecto

Ningún componente se despliega a producción si incumple la postura base establecida.

4. Evaluación de Amenazas y Riesgos

- **¿Qué nos podría salir mal?:** Analizamos fallas lógicas, inyecciones SQL en formularios de registro y brechas en tokens de autenticación rota.
- **¿Por dónde nos podrían atacar?:** Interfaces de API expuestas, entradas de usuario sin sanitizar y dependencias de terceros desactualizadas.
- **¿Qué tan grave sería?:** Evaluación del impacto en la confidencialidad financiera y la integridad de los datos de los usuarios corporativos.

5. Priorización ante Recursos Limitados

Criterio de Criticidad

Ordenamos los hallazgos según su potencial de daño (CVSS score). Las vulnerabilidades que permiten ejecución remota o robo de credenciales masivas van al tope de la lista.

Justificación Técnica

Dado que el tiempo es limitado, se descartan temporalmente detalles estéticos o de baja severidad para concentrar el esfuerzo de ingeniería en mitigar brechas de alto riesgo.

6. Creación de Hitos en el Calendario

Hito 1: Arquitectura

Revisión de requerimientos y modelado de amenazas completado en la semana 2.

Hito 2: Desarrollo

Pruebas estáticas de código (SAST) integradas en el pipeline de CI/CD para la semana 6.

Hito 3: Despliegue

Pruebas de penetración y simulacros de ataque superados antes del lanzamiento (Semana 10).

7. Simulacros y Mejora Continua

Simulacros Prácticos

Ejecución de pruebas controladas imitando ataques reales (ej. pruebas de inyección SQL e intentos de autenticación rota) para medir la velocidad de reacción del equipo.

Mejora Continua

La ciberseguridad nunca se archiva. Cada incidente se convierte en una lección documentada para actualizar los estándares de desarrollo de la empresa.

Pregunta 1: Regla Obligatoria

¿Cuál sería una sola regla obligatoria para todo el equipo?

Regla: "Ninguna entrada de usuario se confía ni se utiliza directamente en consultas o vistas sin antes ser validada, tipada y sanitizada."

Por qué: Como se vio en OWASP Top 10, la gran mayoría de ataques críticos (como Inyección SQL o XSS) explotan la falta de validación de entradas. Al blindar la frontera de entrada del sistema, neutralizamos de golpe una proporción masiva de las vulnerabilidades más destructivas.

Pregunta 2: Priorización de Fallas

¿Cómo decidir qué problema de seguridad atender primero ante tiempo limitado?

Estrategia de Decisión: Se prioriza bajo la matriz de *Impacto vs. Explotabilidad* (alineado con puntuaciones CVSS y OWASP).

Orden de atención: 1) Fallas que permiten acceso administrativo no autorizado o robo masivo de datos; 2) Vulnerabilidades remotas explotables de forma automatizada; 3) Defectos menores en capas secundarias. Se atiende primero aquello que compromete la confidencialidad e integridad directa del núcleo del negocio.

¡Gracias por su atención!

El éxito del desarrollo seguro radica en la colaboración y disciplina constante de todo el equipo técnico.